CYBERSECURITY INTERNSHIP — PRACTICAL LAB REPORT

Day 02: Email Harvesting & Social Engineering Preparation

Intern Name:	Md Peer Siddiqui	**Program / Track:**	Alpha 2 — Cybersecurity Track
Issuing Body:	Sqrock IT Solution	**Date of Execution:**	October 21–22, 2026
Lab Environment:	Authorized Local Practice Testbed (lab_target.html)	**GitHub Repository:**	github.com/MdPeerSiddiqui/Peer-s-Email-Harvester

1. Objective & Scope

To extract public-facing email addresses from web documents using Python and regular expressions, and analyze how harvested contacts are weaponized by threat actors to perform organizational profiling and craft high-conviction social engineering pretexts.

2. Tools and Environment

• **Environment:** Kali Linux 2026.2 (64-bit VirtualBox VM) / Windows 11 Host • **Python:** 3.11.9 / 3.14.0
• **Libraries:** requests (v2.34.2 HTTP fetching), re (RFC 5322 regex engine), colorama (v0.4.6 CLI UI styling)
• **Target:** lab_target.html (Simulated communications directory for *Apex Dynamics Inc.*)

3. Methodology & Implementation

1. **Content Retrieval:** The script reads target HTML content via standard HTTP GET or file streaming.
2. **Pattern Matching:** Evaluates raw DOM text against RFC regex: [a-zA-Z0-9_.+-]+@[a-zA-Z0-9-]+\.[a-zA-Z0-9-.]+
3. **Sanitization & Deduplication:** Cleans punctuation artifacts, normalizes to lowercase, and utilizes set() to remove duplicates.
4. **Threat Modeling:** Automatically maps prefixes to business departments and assigns threat vectors (BEC, macro CV lures).

4. Results and Verification (7 Unique Addresses Discovered)

#	Harvested Address	Department	Risk Level	Primary Threat Vector / Predicted Pretext
1	`billing-invoices@apexdynamics-lab.local`	Finance	CRITICAL	Business Email Compromise (BEC): Fake overdue supplier invoice wire transfer.
2	`careers@apexdynamics-lab.local`	HR / Talent	HIGH	Weaponized Macro Lure: Phishing resume with malicious macro (.docm/.pdf).
3	`finance.desk@apexdynamics-lab.local`	Finance	CRITICAL	CEO Impersonation Fraud: Spoofed executive directing payroll reroute.
4	`hr-department@apexdynamics-lab.local`	HR	HIGH	Employee Verification Lure: Harvesting internal employee directory details.
5	`info@apexdynamics-lab.local`	General	MEDIUM	Reconnaissance Pivot: Mapping mail server signatures and employee hierarchy.
6	`it-support@apexdynamics-lab.local`	IT Support	CRITICAL	Credential Phishing: Cloned SSO login claiming mandatory MFA certificate renewal.
7	`security-ops@apexdynamics-lab.local`	IT Security	CRITICAL	Incident Response Spoofing: Alerting users of active breach to request elevated access.

5. Security Analysis: Potential Misuse & Attack Vectors

Why Harvested Emails are High-Conviction Threat Vectors:
• **Targeted Spear-Phishing:** Unlike bulk spam, scraped departmental addresses enable attackers to craft highly targeted messages. An attacker emailing careers@ knows the recipient expects resumes from strangers, significantly increasing click rates for weaponized documents.
• **Business Email Compromise (BEC):** Harvesting billing-invoices@ enables adversaries to monitor supplier cycles and issue fraudulent payment redirection instructions.
• **Organizational Footprinting:** Public contact formats reveal internal user ID structures and third-party SaaS vendors.
• **Absence of Consent:** Public visibility does not imply consent to receive deceptive or spoofed communications.

6. Defensive Countermeasures & Engineering Mitigations

Defensive Layer	Recommended Implementation	Effectiveness Against Harvesters
1. Contact Obfuscation	Replace plaintext mailto: tags with server-side web contact forms protected by reCAPTCHA v3 or Cloudflare Turnstile.	Completely prevents automated regex web scrapers from identifying contact addresses.
2. Email Authentication	Enforce strict **SPF (Sender Policy Framework)**, **DKIM cryptographic signatures**, and **DMARC policy (p=reject)**.	Prevents external attackers from spoofing legitimate corporate domains in spear-phishing campaigns.
3. Email Gateway Sandboxing	Deploy Advanced Threat Protection (ATP) solutions (e.g. Proofpoint, Mimecast) with attachment sandboxing and link rewriting.	Neutralizes weaponized macro attachments sent to HR and analyzes inbound phishing links.
4. Out-of-Band Verification	Establish mandatory phone verification protocols for any wire transfer or payment change request over $1,000.	Eliminates wire transfer fraud even if finance addresses are successfully targeted.

7. Ethical Compliance & Conclusion

Ethical Scope: All testing was conducted strictly on local simulation assets (lab_target.html) in compliance with the Indian Information Technology Act, 2000 (Section 43 & 66) and the US Computer Fraud and Abuse Act (CFAA). No unauthorized systems were probed.
Conclusion: This exercise demonstrated how simple regex automation exposes an organization's public contact hierarchy and enables multi-stage social engineering. Defense requires combining technical measures (DMARC p=reject, form obfuscation) with strict employee verification policies.

8. Appendix: Practical Execution Proof (Kali Linux 2026)

The following screenshots verify live execution of PEER'S Email Harvester inside Kali Linux, including Git cloning from GitHub, ASCII banner initialization, and full pretexting analysis:





